BIZ-TRANSPAY

90 mesures de sécurité — Plateforme Fintech de paiement et transfert d'argent

Document de référence technique. Objectif : réduire les risques de piratage, fraude, robots, détournement de transactions, erreurs techniques et pertes financières.

■ SÉCURITÉ 1 — Authentification forte

Mot de passe robuste; MFA/2FA; vérification e-mail et téléphone; protection credential stuffing/brute-force. MFA obligatoire pour les administrateurs.

■ SÉCURITÉ 2 — Protection contre le brute-force

Limiter les tentatives de connexion, OTP, réinitialisation, KYC et opérations sensibles. Après anomalies : ralentissement → CAPTCHA → blocage → alerte.

■ SÉCURITÉ 3 — Anti-bot intelligent

Détecter bots, scripts automatisés, requêtes répétitives et création massive de comptes. Combiner WAF + rate limiting + CAPTCHA adaptatif + analyse comportementale.

■ SÉCURITÉ 4 — Protection DDoS

WAF, CDN, protection DDoS, limitation trafic, filtrage IP et protection des endpoints sensibles.

■ SÉCURITÉ 5 — Rate Limiting global

Limiter par IP, compte, appareil, API key, endpoint, pays et opération; limites strictes sur les opérations financières.

■ SÉCURITÉ 6 — Rate Limiting financier

Limiter dépôts, retraits, transferts, conversions, payment links et demandes API.

■ SÉCURITÉ 7 — Protection des sessions

Sessions uniques, difficiles à deviner, expirables, invalidables et liées au compte.

■ SÉCURITÉ 8 — Déconnexion de toutes les sessions

Permettre de déconnecter tous les appareils après changement de mot de passe, suspicion de piratage ou changement MFA.

■ SÉCURITÉ 9 — Réauthentification sensible

Nouvelle authentification avant retrait, changement de mot de passe/e-mail/téléphone, compte bancaire ou API key.

■ SÉCURITÉ 10 — Autorisation serveur

À chaque requête : vérifier l'identité, les permissions et la ressource. Ne jamais faire confiance au frontend.

■ SÉCURITÉ 11 — Protection CSRF

CSRF token, SameSite, Origin/Referer lorsque approprié et validation serveur pour les opérations sensibles.

■ SÉCURITÉ 12 — CORS strict

Ne pas utiliser inutilement Access-Control-Allow-Origin: *. Autoriser uniquement les domaines nécessaires.

■ SÉCURITÉ 13 — HTTPS obligatoire

HTTPS, TLS moderne, HSTS et certificats valides. Aucune donnée financière sensible en HTTP.

■ SÉCURITÉ 14 — Security Headers

HSTS, CSP, X-Content-Type-Options, Referrer-Policy, Permissions-Policy et protections anti-framing.

■ SÉCURITÉ 15 — Protection des API

Authentification, autorisation, validation, rate limiting, timeout, idempotence, logs et monitoring.

■ SÉCURITÉ 16 — API Keys sécurisées

Clés longues et aléatoires, serveur uniquement, révocation, rotation, séparation test/live et scopes.

■ SÉCURITÉ 17 — Secrets serveur

API keys, secrets, DB passwords, JWT/webhook secrets et clés de chiffrement jamais dans frontend ou GitHub.

■ SÉCURITÉ 18 — Chiffrement

Chiffrer KYC, données personnelles, informations bancaires, secrets et données financières critiques.

■ SÉCURITÉ 19 — Base de données privée

Réseau privé, firewall, comptes séparés, permissions minimales, TLS et sauvegardes; aucune DB directement exposée.

■ SÉCURITÉ 20 — Redis sécurisé

Réseau privé, authentification, ACL, firewall, TLS si nécessaire et aucune exposition publique.

■ SÉCURITÉ 21 — Webhooks sécurisés

Vérifier signature, secret, timestamp, transaction ID, montant, devise, marchand, statut et référence fournisseur.

■ SÉCURITÉ 22 — Idempotence

Une transaction ne doit être traitée qu'une seule fois, même si le fournisseur renvoie plusieurs fois SUCCESS.

■ SÉCURITÉ 23 — Validation serveur du montant

Le backend recalcule montant + frais + devise + montant final.

■ SÉCURITÉ 24 — Ledger financier

Ne jamais modifier directement une balance; utiliser un ledger avec mouvements, références, devise, timestamp et statut.

■ SÉCURITÉ 25 — Transactions atomiques

Une opération financière est entièrement enregistrée ou annulée en cas d'échec.

■ SÉCURITÉ 26 — Race conditions

Transactions DB, verrous, contraintes et idempotency keys pour empêcher deux dépenses simultanées du même solde.

■ SÉCURITÉ 27 — Vérification du solde

Avant retrait : solde disponible ≥ montant + frais, puis verrouillage du montant nécessaire.

■ SÉCURITÉ 28 — Réservation des fonds

Retrait lancé : montant disponible → montant réservé; le montant réservé ne peut plus être dépensé.

■ SÉCURITÉ 29 — Limites financières

Minimum, maximum, quotidien, hebdomadaire, mensuel et nombre de transactions; limites selon KYC.

■ SÉCURITÉ 30 — Moteur antifraude

Analyser montant, fréquence, IP, appareil, pays, historique, bénéficiaire et comportement.

■ SÉCURITÉ 31 — Score de risque

FAIBLE → MOYEN → ÉLEVÉ → CRITIQUE; mettre en attente les transactions critiques.

■ SÉCURITÉ 32 — Détection d'anomalies

Détecter changements brusques, multiplication des retraits, nouveau bénéficiaire/appareil/localisation et comportements inhabituels.

■ SÉCURITÉ 33 — Device Risk

Identifier appareil, navigateur, système, IP et localisation approximative comme signaux de risque.

■ SÉCURITÉ 34 — Création massive de comptes

Limiter comptes/IP, appareil, numéro et e-mail; CAPTCHA et vérifications supplémentaires.

■ SÉCURITÉ 35 — Abus des OTP

Limiter demandes, renvois, validations et tentatives pour empêcher l'automatisation abusive.

■ SÉCURITÉ 36 — Anti-énumération

Ne pas permettre de découvrir facilement comptes, e-mails, numéros ou références internes.

■ SÉCURITÉ 37 — Données personnelles

Afficher uniquement les informations nécessaires et masquer les données sensibles lorsque possible.

■ SÉCURITÉ 38 — KYC sécurisé

Validation MIME, taille, antivirus, stockage privé, URL temporaire et contrôle d'accès.

■ SÉCURITÉ 39 — Stockage KYC privé

Aucune URL publique permanente; stockage privé → URL temporaire signée → expiration.

■ SÉCURITÉ 40 — Protection SSRF

Pour les URL externes : allowlist, blocage IP privées/métadonnées cloud, ports et protocoles limités.

■ SÉCURITÉ 41 — Validation des entrées

Valider montant, devise, pays, opérateur, téléphone, e-mail et identifiants.

■ SÉCURITÉ 42 — SQL Injection

Requêtes paramétrées, ORM correctement configuré et aucune concaténation directe des entrées utilisateur.

■ SÉCURITÉ 43 — XSS

Encoder/sanitiser les données affichées, notamment descriptions, noms marchands et payment links.

■ SÉCURITÉ 44 — Mass Assignment

Empêcher la modification non autorisée de role, balance ou autres champs sensibles via les requêtes.

■ SÉCURITÉ 45 — Autorisation objet par objet

Pour chaque ressource, vérifier côté serveur que l'utilisateur possède le droit d'accès.

■ SÉCURITÉ 46 — Fonctions admin

Séparer Utilisateur, Marchand, Support, Admin et Super Admin; permissions minimales.

■ SÉCURITÉ 47 — Panneau admin

MFA obligatoire, IP allowlist si possible, session courte, réauthentification, logs et alertes.

■ SÉCURITÉ 48 — Séparation des privilèges

Éviter qu'un seul compte configure les frais, approuve les retraits et modifie les logs. Maker → Checker.

■ SÉCURITÉ 49 — Journal d'audit

Enregistrer connexions, dépôts, retraits, transferts, modifications, actions admin et changements de configuration.

■ SÉCURITÉ 50 — Logs immuables

Stockage séparé et accès restreint afin d'empêcher la suppression facile des traces.

■ SÉCURITÉ 51 — Alertes de sécurité

Alertes sur échecs de connexion, retraits inhabituels, changement bancaire, créations massives, activité admin et webhooks anormaux.

■ SÉCURITÉ 52 — Monitoring 24/7

CPU, RAM, disque, DB, Redis, API, erreurs, latence, transactions et webhooks.

■ SÉCURITÉ 53 — Protection des fournisseurs

Timeout, retry contrôlé, circuit breaker, monitoring, logs et limites par gateway.

■ SÉCURITÉ 54 — Isolation des gateways

Isoler les credentials et traitements : Gateway A ≠ Gateway B ≠ Gateway C.

■ SÉCURITÉ 55 — Validation des réponses fournisseurs

Vérifier transaction ID, montant, devise, statut, référence et marchand.

■ SÉCURITÉ 56 — Circuit Breaker

En cas de panne provider : timeout → erreurs → suspension temporaire → reprise progressive.

■ SÉCURITÉ 57 — Kill Switch financier

Désactivation immédiate des dépôts, retraits, transferts, conversion, API, payment links, pays, opérateur ou gateway.

■ SÉCURITÉ 58 — Emergency Lockdown

Mode SECURITY LOCKDOWN pour bloquer les opérations financières tout en conservant un accès admin sécurisé.

■ SÉCURITÉ 59 — Erreurs techniques

Ne jamais exposer Redis error, SQL error, API key invalid ou stack trace au client; logs sécurisés uniquement.

■ SÉCURITÉ 60 — Sauvegardes automatiques

Sauvegarder DB, configuration, ledger et données essentielles; stratégie 3-2-1 lorsque adaptée.

■ SÉCURITÉ 61 — Test de restauration

Tester régulièrement backup → restauration → vérification d'intégrité.

■ SÉCURITÉ 62 — Disaster Recovery

Procédure en cas de piratage, panne, corruption DB, ransomware ou panne fournisseur; définir RPO et RTO.

■ SÉCURITÉ 63 — Dev/Test/Production

Séparer développement, test, staging et production; clés et bases distinctes.

■ SÉCURITÉ 64 — CI/CD sécurisé

Avant déploiement : tests, SAST, dependency scanning, secret scanning, tests sécurité et permissions.

■ SÉCURITÉ 65 — Scan des dépendances

Scanner npm, Python, PHP, Docker et packages système; corriger les vulnérabilités critiques.

■ SÉCURITÉ 66 — Sécurité Docker

Images minimales, pas de root, scan, secrets hors image et ports minimaux.

■ SÉCURITÉ 67 — Durcissement serveur

Firewall, ports minimaux, mises à jour, monitoring, intrusion detection et comptes admin séparés.

■ SÉCURITÉ 68 — SSH sécurisé

Clés SSH, MFA si possible, restriction IP, pas de login root, fail2ban/équivalent et logs.

■ SÉCURITÉ 69 — Credentials fournisseurs

API key, secret, merchant ID et webhook secret stockés séparément et jamais dans le code.

■ SÉCURITÉ 70 — Abus des API

Quota, rate limit, scopes, limites financières et journalisation par marchand.

■ SÉCURITÉ 71 — Flux sensibles

Renforcer retrait, transfert, changement bénéficiaire, changement bancaire et conversion contre l'automatisation abusive.

■ SÉCURITÉ 72 — Confirmation des retraits

Retrait à risque : demande → contrôle → confirmation forte → traitement.

■ SÉCURITÉ 73 — Protection du bénéficiaire

Nouveau bénéficiaire : confirmation, notification, éventuellement délai de sécurité et surveillance du premier transfert.

■ SÉCURITÉ 74 — Blocage après modification critique

Après changement téléphone/e-mail/mot de passe/bénéficiaire, limiter temporairement certaines opérations selon le risque.

■ SÉCURITÉ 75 — Prise de contrôle du compte

Nouvel appareil + nouvelle IP + changement mot de passe + retrait important → risque élevé.

■ SÉCURITÉ 76 — Anti-phishing

Informer sur le domaine officiel; ne jamais demander mot de passe ou clé API; alertes sur connexions inhabituelles.

■ SÉCURITÉ 77 — Sécurité e-mail

SPF, DKIM, DMARC, liens HTTPS et aucun secret dans les e-mails.

■ SÉCURITÉ 78 — Notifications Telegram/SMS

Ne jamais envoyer mot de passe, API key, secret ou données KYC sensibles.

■ SÉCURITÉ 79 — Anti-rejeu

Timestamp, nonce, signature, expiration et idempotency key pour empêcher la réutilisation d'une ancienne requête.

■ SÉCURITÉ 80 — Expiration des demandes

Les demandes de paiement/retrait expirent si aucune confirmation n'arrive dans le délai prévu.

■ SÉCURITÉ 81 — Réconciliation financière

Comparer Biz-transPay ↔ Provider ↔ Ledger ↔ Banque/Wallet pour détecter écarts et doubles mouvements.

■ SÉCURITÉ 82 — Réconciliation automatique

Rechercher les transactions PENDING trop longtemps et vérifier leur statut auprès du fournisseur.

■ SÉCURITÉ 83 — Crédits fantômes

Ne jamais créditer sur payment initiated; attendre une confirmation valide du fournisseur.

■ SÉCURITÉ 84 — Retraits fantômes

REQUESTED → PROCESSING → SUCCESS / FAILED / EXPIRED; ne jamais assimiler requested à successful.

■ SÉCURITÉ 85 — Vérification comptable

Vérifier périodiquement que le solde ledger correspond à la somme des mouvements; alerter sur toute différence.

■ SÉCURITÉ 86 — Tests de sécurité automatisés

Tester authentification, API, permissions, webhooks, paiements, retraits, injections, XSS, CSRF, rate limiting et idempotence.

■ SÉCURITÉ 87 — Pentest autorisé

Tests d'intrusion périodiques et autorisés sur frontend, backend, API, admin, payment links, webhooks et infrastructure.

■ SÉCURITÉ 88 — Inventaire des API

Maintenir l'inventaire des endpoints, versions, API keys, webhooks, fournisseurs et services internes.

■ SÉCURITÉ 89 — Réponse aux incidents

Détection → Blocage → Investigation → Correction → Restauration → Réconciliation → Rapport; responsables clairement définis.

■ SÉCURITÉ 90 — Centre de sécurité financier

Security Center avec risque global, attaques/bots, IP suspectes, comptes verrouillés, transactions à risque, retraits bloqués, webhooks suspects, anomalies de solde, providers en erreur, sauvegardes et réconciliation.

PRIORITÉS CRITIQUES

• Ledger financier + transactions atomiques

• Idempotence des paiements

• Vérification serveur des paiements

• Webhooks signés et vérifiés

• Protection contre les doubles retraits

• MFA obligatoire pour l'administration

• Rate limiting + anti-bot + WAF

• Moteur antifraude

• Réconciliation Provider ↔ Biz-transPay

• Kill Switch financier

• Protection des API et autorisations objet par objet

• Logs d'audit immuables

• Sauvegardes + restauration testée

• Isolation des fournisseurs et de leurs secrets

• Security Center avec alertes en temps réel

Cette liste constitue une base technique et ne remplace pas un audit de sécurité, un pentest autorisé ou une validation réglementaire/juridique.